EPICODE · CYBERSECURITY ANALYST

Active Directory, SIEM & Detection

Costruzione di un dominio Active Directory, simulazione di attacchi da una macchina Kali esterna e verifica della capacità di rilevamento di un SIEM (Splunk) tramite correlazione fra azioni offensive ed eventi di log.

AUTORE **Samuele Asaro**

PROGETTO **W24D4 — Progetto di fine modulo**

DATA **12 ottobre 2026**

STATO **Progetto completato · Attacchi rilevati dal SIEM**

Windows Server 2022 · Splunk · Sysmon · Kali Linux

Report v1.0

— Indice

1 **Obiettivo e contesto** 3

2 **Architettura del laboratorio** 3

3 **Domain Controller (Windows Server 2022)** 4

4 **Telemetria: Sysmon** 5

5 **SIEM: Splunk su Ubuntu** 6

6 **Raccolta log: Universal Forwarder** 7

7 **Client di dominio (Windows 10 Pro)** 8

8 **Fase offensiva — attacchi dalla Kali** 9

9 **Detection sul SIEM** 11

10 **Conclusioni** 12

IN BREVE

Il laboratorio è stato costruito, attaccato e monitorato con successo. Dalla Kali sono stati eseguiti attacchi per tutte e tre le categorie richieste (ricognizione, credenziali/Kerberos, movimento laterale) e, per ciascuno, è stato individuato su Splunk l'**evento corrispondente**, con correlazione temporale. Il SIEM ha rilevato il password spraying (4625), il Kerberoasting (4769), le richieste Kerberos (4768) e il movimento laterale PsExec (7045). Il progetto è completo end-to-end.

1 Obiettivo e contesto

Il progetto consiste nel costruire un piccolo dominio **Active Directory**, attaccarlo da una macchina **Kali Linux** esterna al dominio e verificare **se e come un SIEM rileva gli attacchi**.

Il valore dell'esercizio sta nella **correlazione**: ogni azione offensiva viene annotata con il proprio orario e quindi ricercata all'interno del SIEM, per stabilire quale traccia ha lasciato nei log e quali eventi la rendono riconoscibile. È lo stesso flusso di lavoro che un analista SOC segue di fronte a un allarme.

Gli attacchi sono organizzati nelle tre categorie richieste: **ricognizione ed enumerazione**, **attacchi su credenziali / Kerberos** e **movimento laterale / esecuzione comandi**.

2 Architettura del laboratorio

L'ambiente è composto da quattro macchine virtuali in VirtualBox, collegate su rete **Host-only** `192.168.56.0/24`. Le macchine Windows/Ubuntu dispongono di un secondo adattatore **NAT** usato solo in fase di installazione per i download. La Kali è volutamente **esterna al dominio**, nel ruolo dell'attaccante.

Ruolo	Sistema operativo	IP (lab)	Stato
Domain Controller	Windows Server 2022	`192.168.56.10`	**Completato**
SIEM	Ubuntu + Splunk Free	`192.168.56.30`	**Completato**
Client di dominio	Windows 10 Pro	`192.168.56.20`	**Completato (nel dominio)**
Attaccante	Kali Linux	`192.168.56.101`	**Pronta (fuori dominio)**

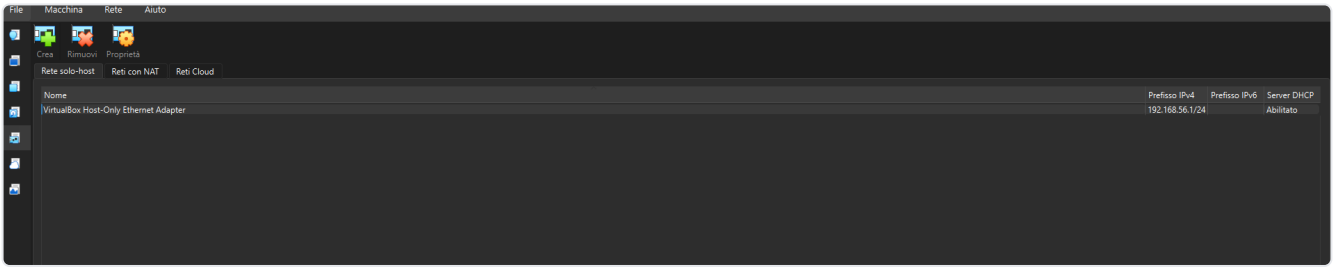


Fig. 1 Rete Host-only in VirtualBox: subnet 192.168.56.0/24 del laboratorio.

> **NOTA DI PROGETTAZIONE**
>
> Il Domain Controller ha indirizzo statico ed è anche il server DNS del dominio. Tutte le macchine del dominio devono usare il DC come DNS: è il presupposto perché il join e la risoluzione dei nomi funzionino correttamente.

3 Domain Controller (Windows Server 2022)

Il DC è il nodo centrale del laboratorio: ospita Active Directory, custodisce utenti e credenziali e governa l'autenticazione del dominio `lab.local`. È stato creato come VM dedicata, configurato con IP statico e promosso a controller di dominio.

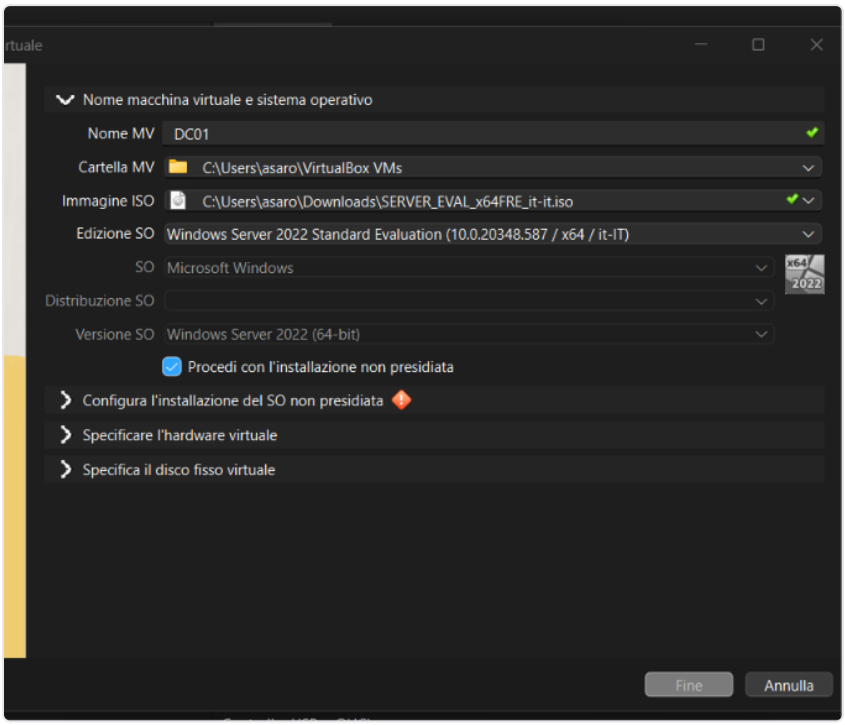


Fig. 2 Creazione della VM del Domain Controller con ISO di Windows Server 2022.

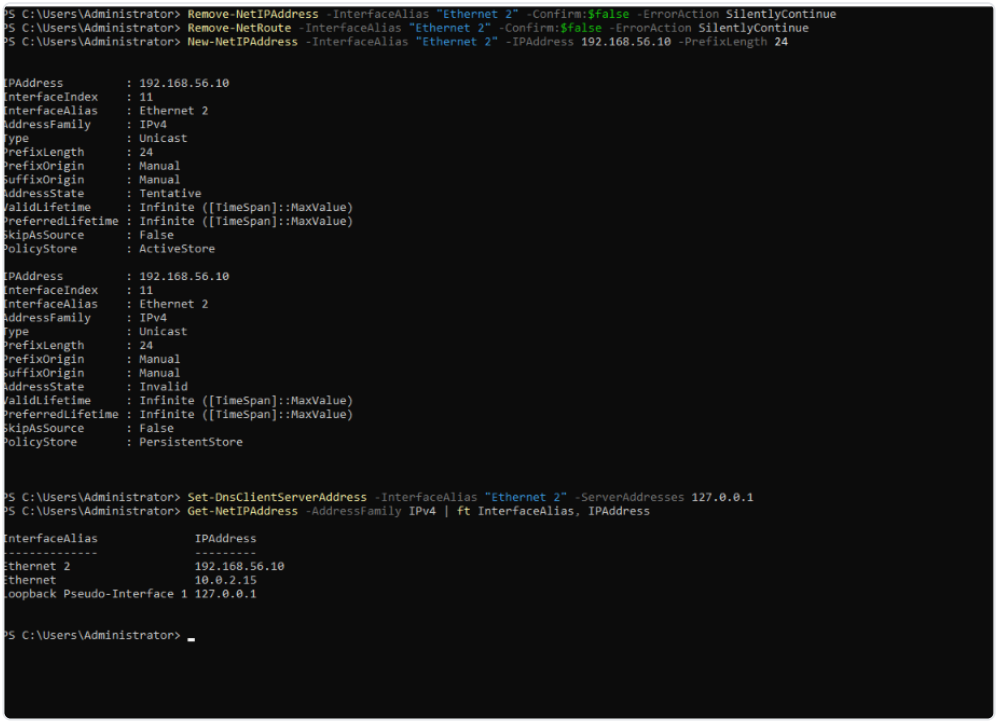


Fig. 3 Assegnazione dell'indirizzo statico 192.168.56.10 alla scheda del lab.

Dominio, utenti e risorse

Creato il dominio `lab.local` (controller `DC01.lab.local`) sono stati definiti utenti, un gruppo e una share SMB. Due account sono stati configurati con **debolezze volute**, che renderanno possibili gli attacchi Kerberos:

Oggetto	Dettaglio	Finalità
`mrossi` , `lverdi`	Utenti standard, gruppo `IT-Support`	Attività di dominio
`abianchi`	Pre-autenticazione Kerberos disabilitata	Bersaglio **AS-REP Roasting**
`svc_sql`	Account di servizio con SPN, password debole	Bersaglio **Kerberoasting**
`Condivisa`	Share SMB (`C:\Condivisa`)	Enumerazione e accessi ai file

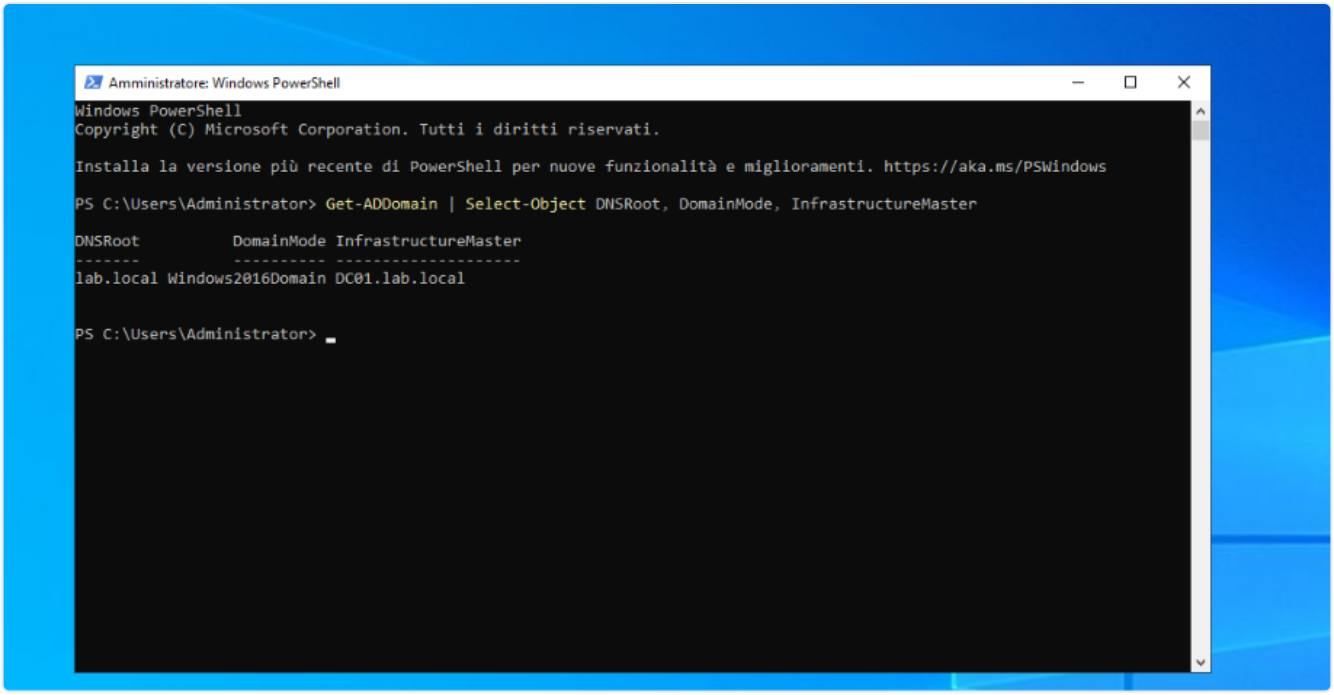


Fig. 4 Dominio lab.local attivo: output di Get-ADDomain con DC01.lab.local.

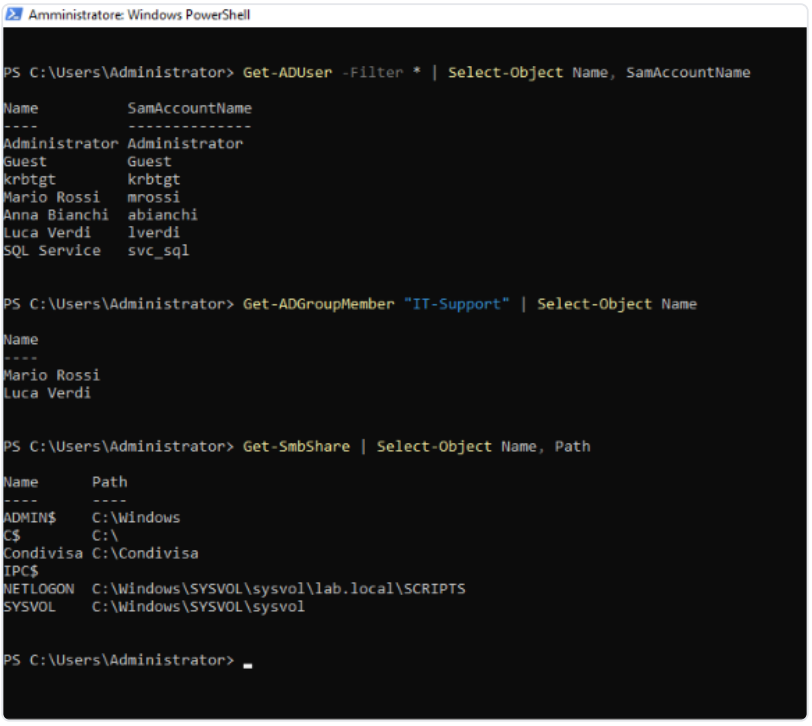


Fig. 5 Utenti di dominio, membri del gruppo IT-Support e share Condivisa.

AUDITING

Sul DC è stato abilitato l'auditing avanzato (creazione processi, accesso alle share, inclusione della riga di comando negli eventi `4688`): senza la generazione di questi eventi il SIEM non avrebbe nulla da rilevare.

4 Telemetria: Sysmon

Oltre ai log nativi di Windows, sul DC è stato installato **Sysmon** con la configurazione di SwiftOnSecurity. Sysmon fornisce una telemetria dettagliata su creazione di processi, connessioni di rete e attività di sistema: è ciò che rende realmente **visibili** le tecniche offensive all'interno del SIEM.

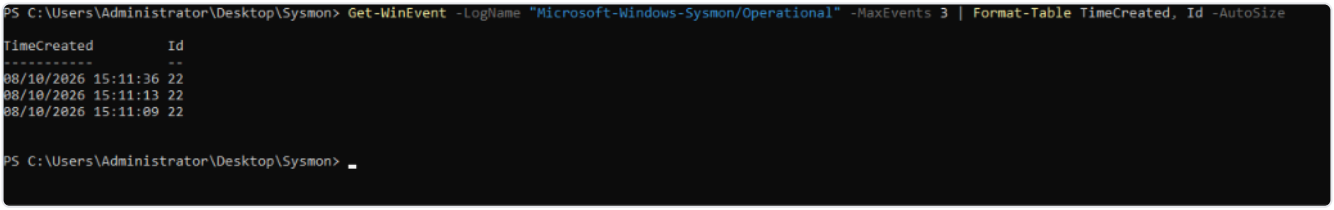


Fig. 6 Sysmon operativo sul DC: eventi registrati nel log Microsoft-Windows-Sysmon/Operational.

> **PERCHÉ È IMPORTANTE**
>
> Molte azioni (ad esempio l'esecuzione di comandi da remoto) risultano poco evidenti nei soli log di sicurezza. Sysmon aggiunge il contesto — processo padre, riga di comando, hash — che trasforma un evento generico in un indicatore utile per la detection.

5 SIEM: Splunk su Ubuntu

Il SIEM è il cuore analitico del laboratorio. È stato installato **Splunk Enterprise** (licenza **Free**) su una VM Ubuntu dedicata, con IP statico `192.168.56.30`. Splunk raccoglie in un unico punto i log provenienti dalle macchine del dominio e permette di ricercarli per individuare le tracce degli attacchi.



Fig. 7 VM Splunk: configurazione dell'IP statico 192.168.56.30 via netplan.

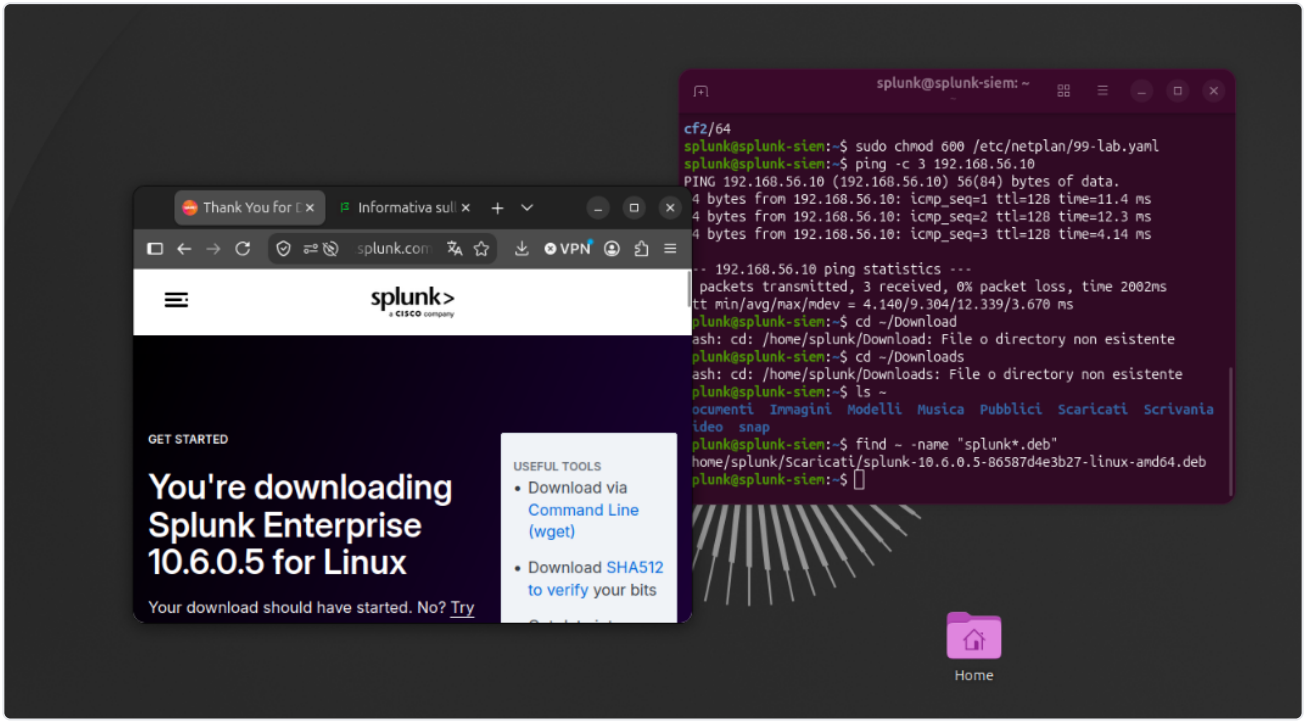


Fig. 8 Verifica di connettività dal SIEM verso il Domain Controller (ping riuscito).

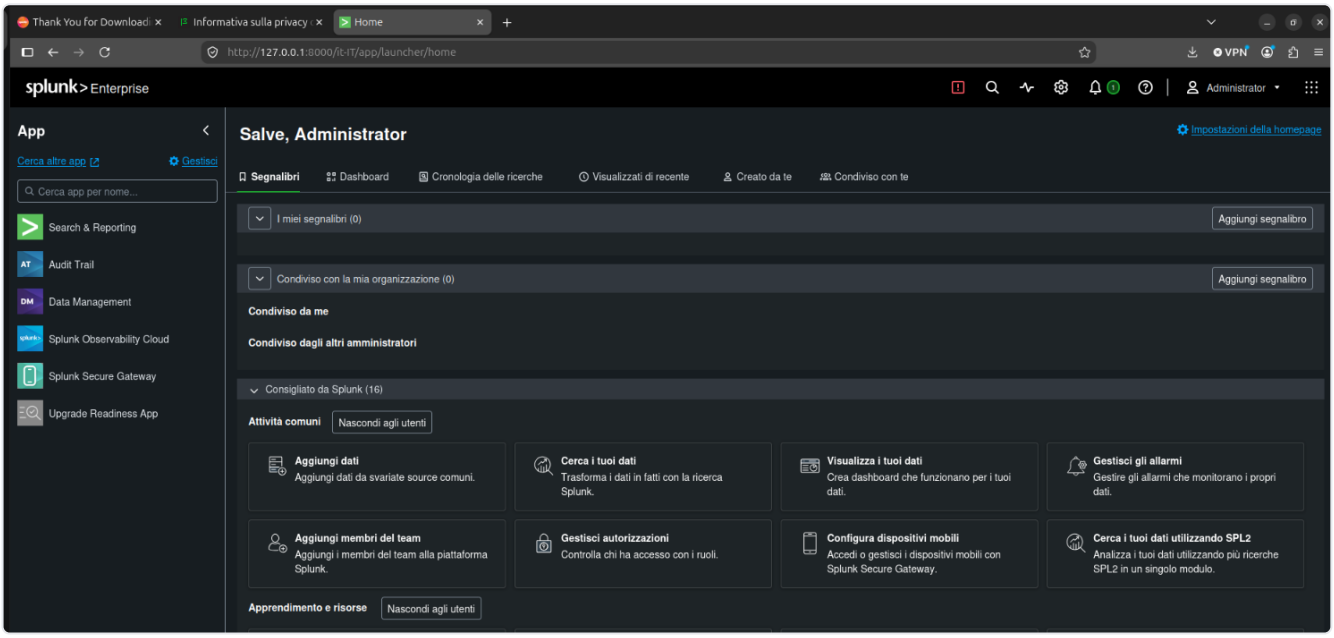


Fig. 9 Interfaccia web di Splunk Enterprise (licenza Free) operativa.

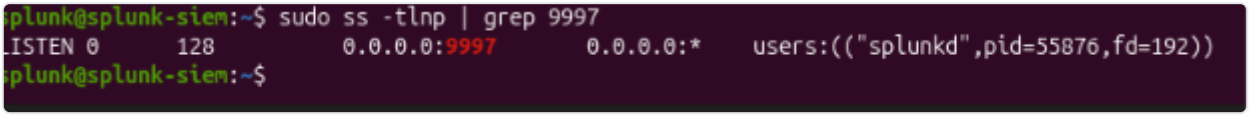


Fig. 10 Splunk in ascolto sulla porta di ricezione 9997 (verifica con ss).

6 Raccolta log: Universal Forwarder

Per trasferire i log dal Domain Controller al SIEM è stato installato sul DC lo **Splunk Universal Forwarder**, l'agente che inoltra gli eventi verso Splunk (`192.168.56.30:9997`). Sono stati inclusi i log di **Security**, **System**, **Application** e **Sysmon**.

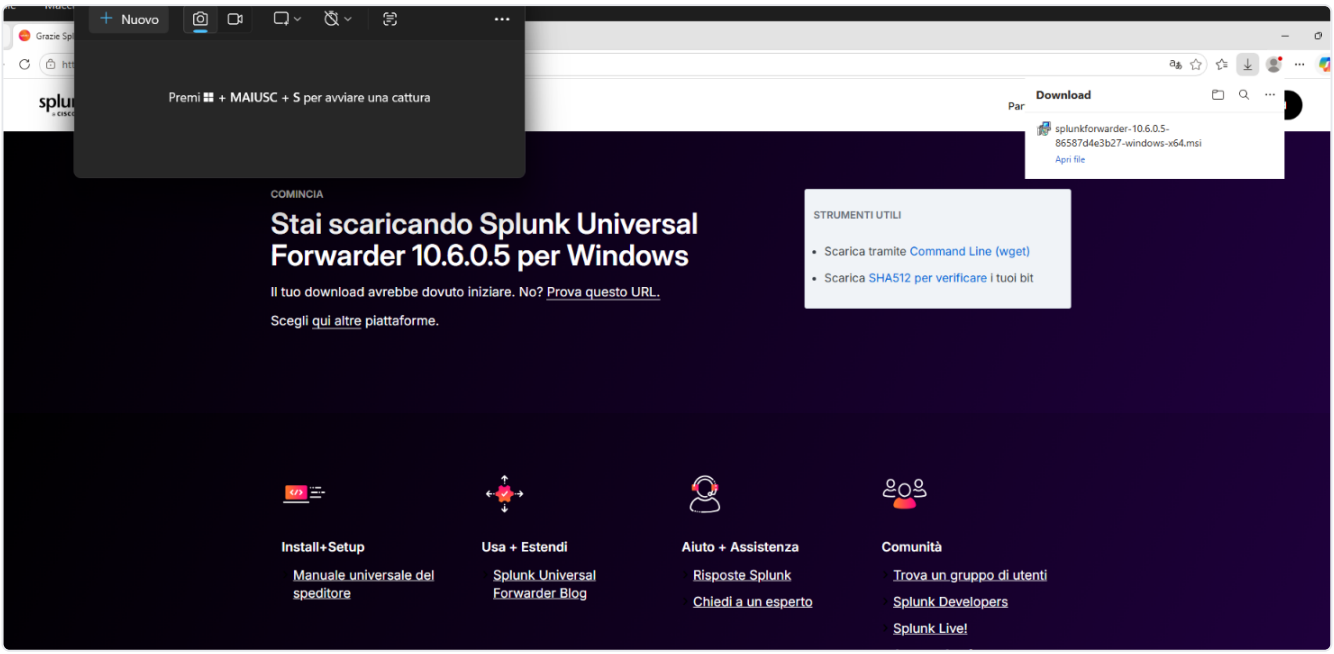


Fig. 11 Download dello Splunk Universal Forwarder per Windows.

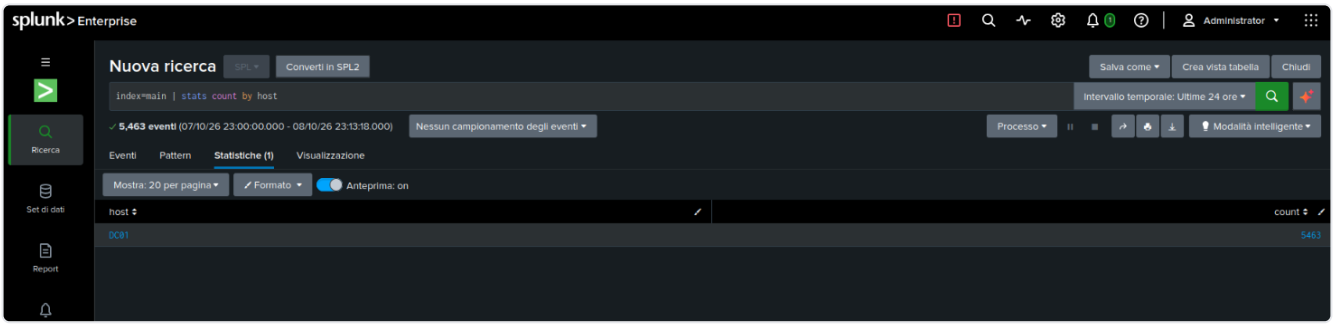


Fig. 12 Conferma end-to-end: 5.463 eventi ricevuti da DC01 e indicizzati in Splunk.

> **RISULTATO**
>
> La query `index=main | stats count by host` mostra l'host **DC01** con migliaia di eventi: la catena **DC → Universal Forwarder → Splunk** funziona correttamente e il SIEM sta raccogliendo dati reali. L'infrastruttura di monitoraggio è pronta per la fase offensiva.

7 Client di dominio (Windows 10 Pro)

Il quarto nodo è una postazione client **Windows 10 Pro** (`CLIENT01`), che rappresenta il computer di un dipendente. È stato configurato con IP statico `192.168.56.20` e, soprattutto, con il **DNS puntato al Domain Controller** (`192.168.56.10`): è la condizione che permette alla macchina di trovare e raggiungere il dominio.

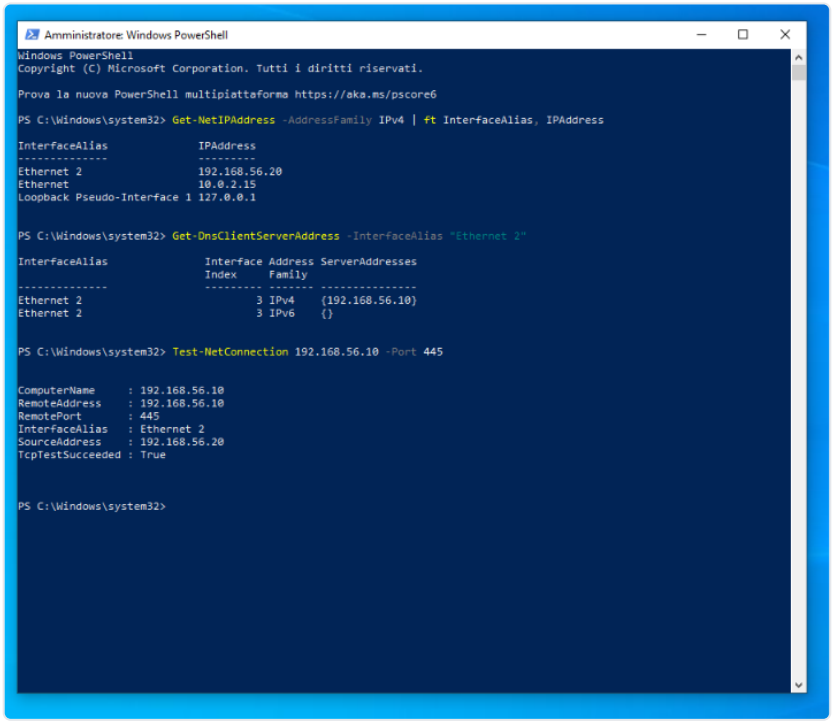


Fig. 13 Client: IP statico 192.168.56.20 e DNS impostato sul Domain Controller.

Unione al dominio e logon utente

Il client è stato **unito al dominio** `lab.local` e, dopo il riavvio, è stato effettuato con successo il **logon con l'utente di dominio** `LAB\mrossi` . Questo accesso genera sul DC gli eventi di logon (`4624`) che costituiranno parte del materiale analizzato nella fase di detection. La raggiungibilità del DC è stata verificata sulla porta SMB (445).

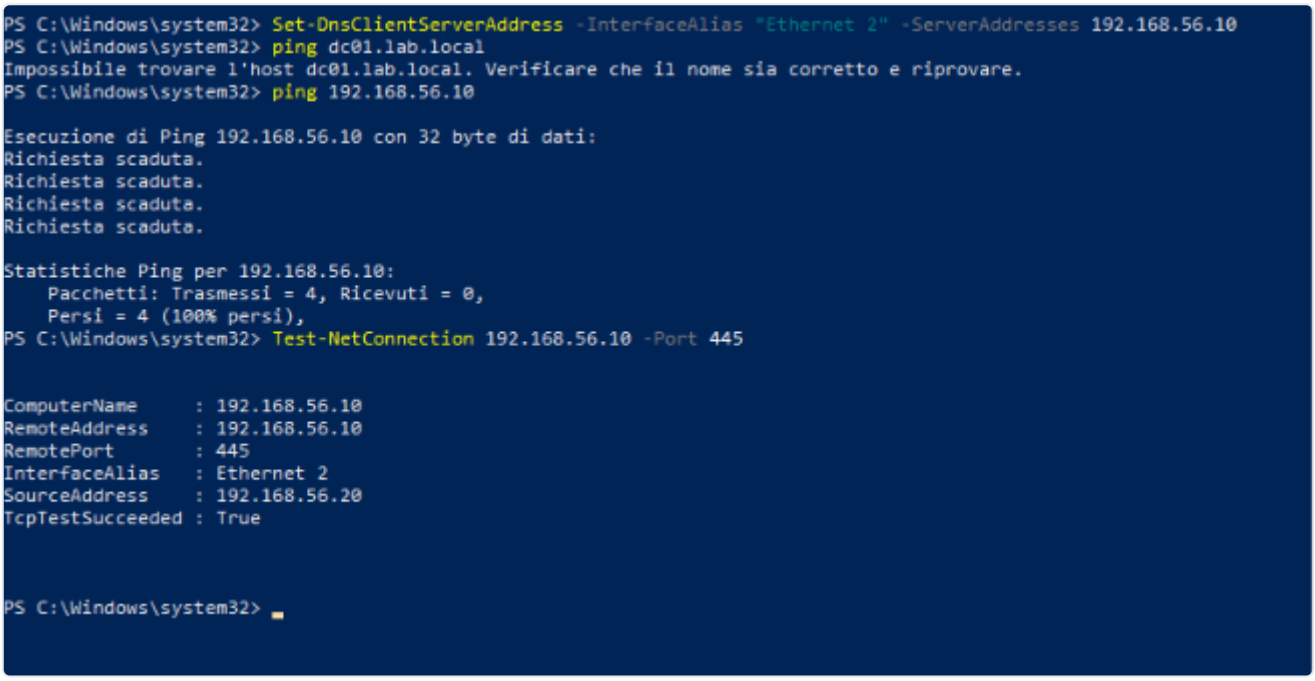


Fig. 14 Verifica della raggiungibilità del Domain Controller dal client (porta 445).

> **NOTA TECNICA**
>
> La build 25H2 di Windows 11 non si avviava in VirtualBox (schermata nera in modalità UEFI). Si è quindi adottato **Windows 10 Pro**, equivalente ai fini del progetto — la traccia richiede un generico "Client Windows" — e più stabile in ambiente virtualizzato. L'edizione **Pro** è necessaria perché, a differenza della Home, consente l'unione a un dominio Active Directory.

8 Fase offensiva — attacchi dalla Kali

Dalla macchina **Kali** (`192.168.56.101` , esterna al dominio) sono stati eseguiti attacchi per le tre categorie richieste. Per ogni azione è stato registrato l'orario, da usare per la correlazione con i log del SIEM.

9.1 — Ricognizione ed enumerazione

Una scansione `nmap` ha individuato il Domain Controller dalle porte caratteristiche (88 Kerberos, 389 LDAP, 445 SMB, 636 LDAPS, 3268 Global Catalog). Con le credenziali di un utente di dominio sono stati poi enumerati **utenti, gruppi, share e criteri password** tramite `netexec` , rivelando tra l'altro la share `Condivisa` e l'assenza di lockout sugli account.



Fig. 15 nmap: individuazione del DC dalle porte di dominio (88, 389, 445, 636, 3268).



Fig. 16 Enumerazione del dominio: utenti, share e password policy via netexec.

9.2 — Attacchi su credenziali / Kerberos

Sono stati portati tre attacchi distinti contro le credenziali di dominio:

Tecnica	Bersaglio	Esito
AS-REP Roasting	`abianchi` (pre-auth disabilitata)	**Password craccata:** `Estate2024`
Kerberoasting	`svc_sql` (account con SPN)	**Password craccata:** `Summer2024`
Password spraying	tutti gli utenti	**Trovati** `mrossi` **e** `lverdi`

Gli hash Kerberos estratti sono stati decifrati offline con **John the Ripper** usando una wordlist di password deboli a tema stagionale — un pattern di attacco realistico.

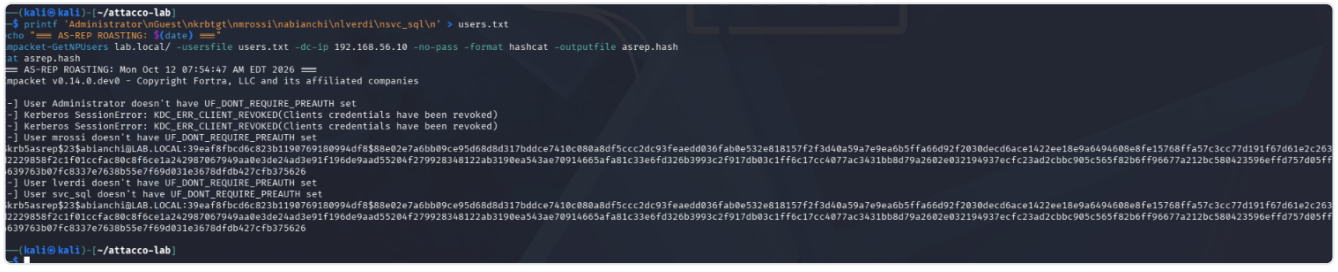


Fig. 17 AS-REP Roasting: estrazione dell'hash dell'utente abianchi.

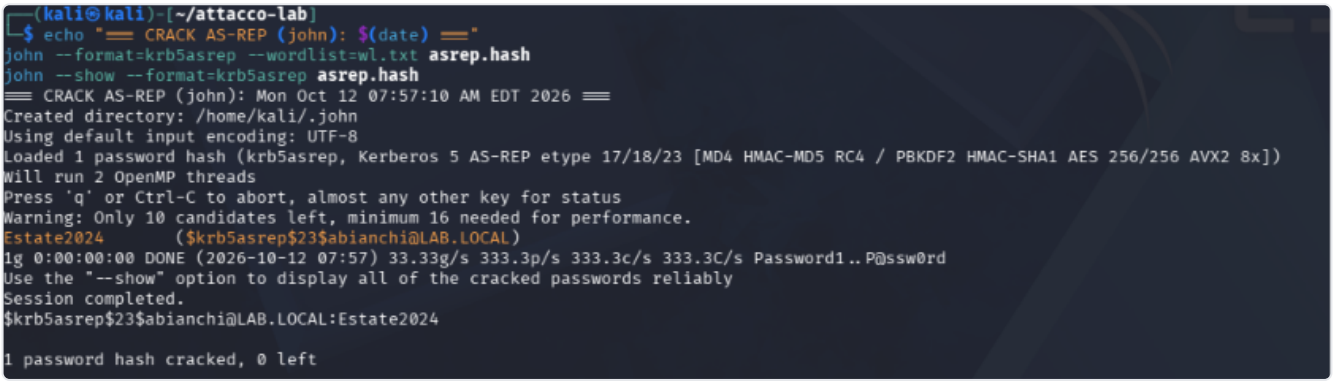


Fig. 18 Crack offline dell'hash AS-REP → abianchi : Estate2024.



Fig. 19 Kerberoasting su svc_sql e crack del ticket → Summer2024.

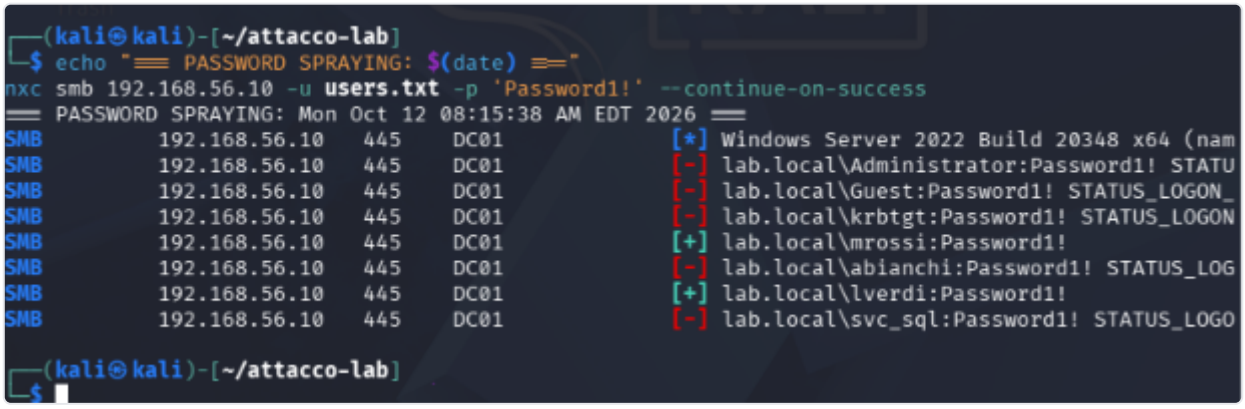


Fig. 20 Password spraying: mrossi e lverdi usano la stessa password debole.

9.3 — Movimento laterale / esecuzione comandi

Con credenziali amministrative è stato eseguito **PsExec** (Impacket) contro il Domain Controller: lo strumento carica un eseguibile sulla share `ADMIN$`, installa un **servizio** e apre una shell remota. Il comando `whoami` ha restituito `nt authority\system`, confermando il controllo totale della macchina.

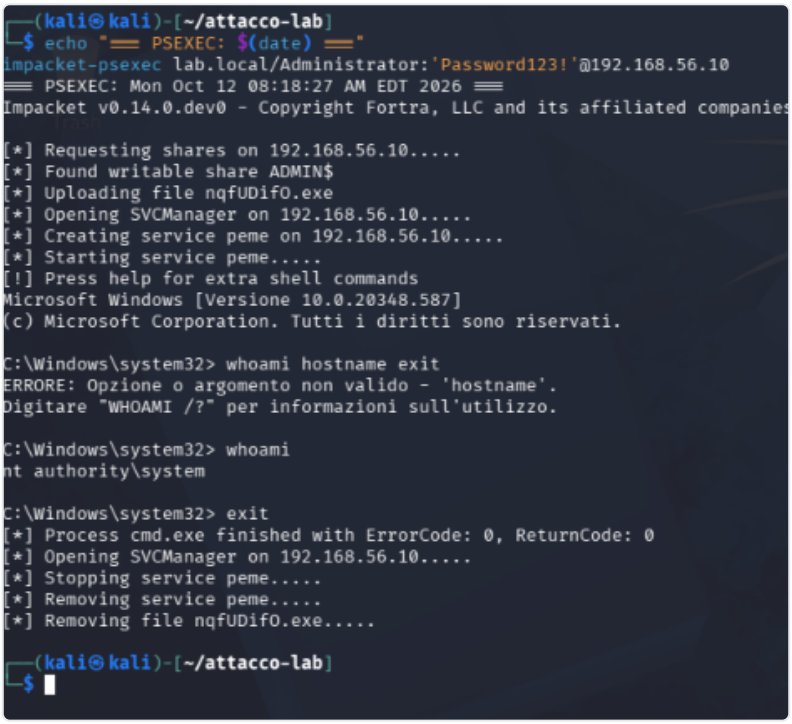


Fig. 21 PsExec: creazione del servizio e shell SYSTEM sul Domain Controller.

9 Detection sul SIEM

Per ciascun attacco è stato ricercato su Splunk l'evento corrispondente, filtrando per Event ID e confrontando l'orario con quello dell'azione offensiva. **Tutti gli attacchi hanno lasciato una traccia rilevabile.**

Attacco	Event ID	Ricerca Splunk	Rilevato
Password spraying	`4625`	`index=main EventCode=4625`	**Sì (61 eventi)**
Kerberoasting	`4769`	`EventCode=4769 Service_Name=svc_sql`	**Sì**
AS-REP / richieste TGT	`4768`	`index=main EventCode=4768`	**Sì**
Movimento laterale (PsExec)	`7045`	`index=main EventCode=7045`	**Sì**

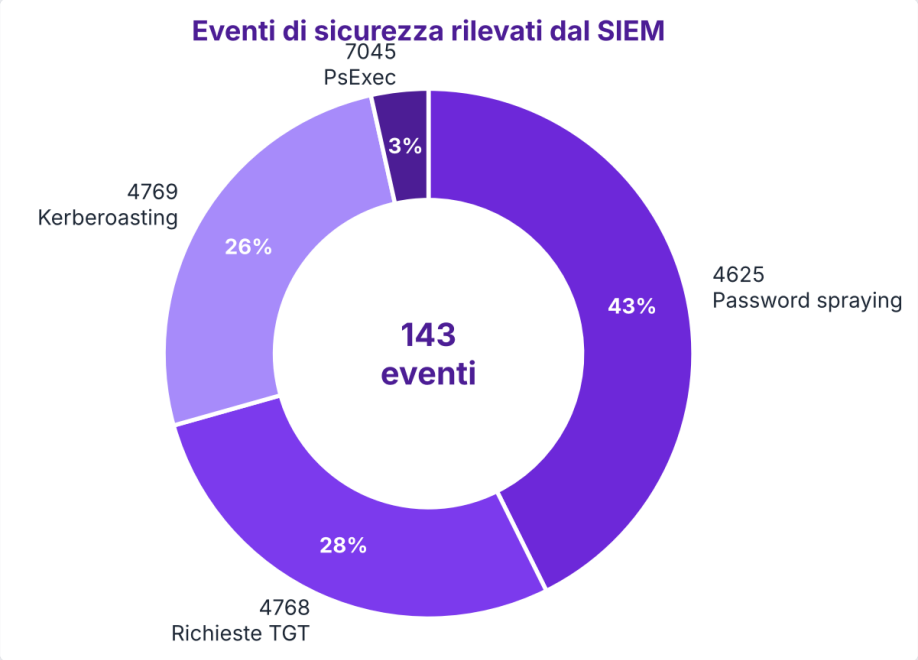


Fig. 22 Distribuzione degli eventi di sicurezza generati dagli attacchi e rilevati dal SIEM (143 eventi totali).

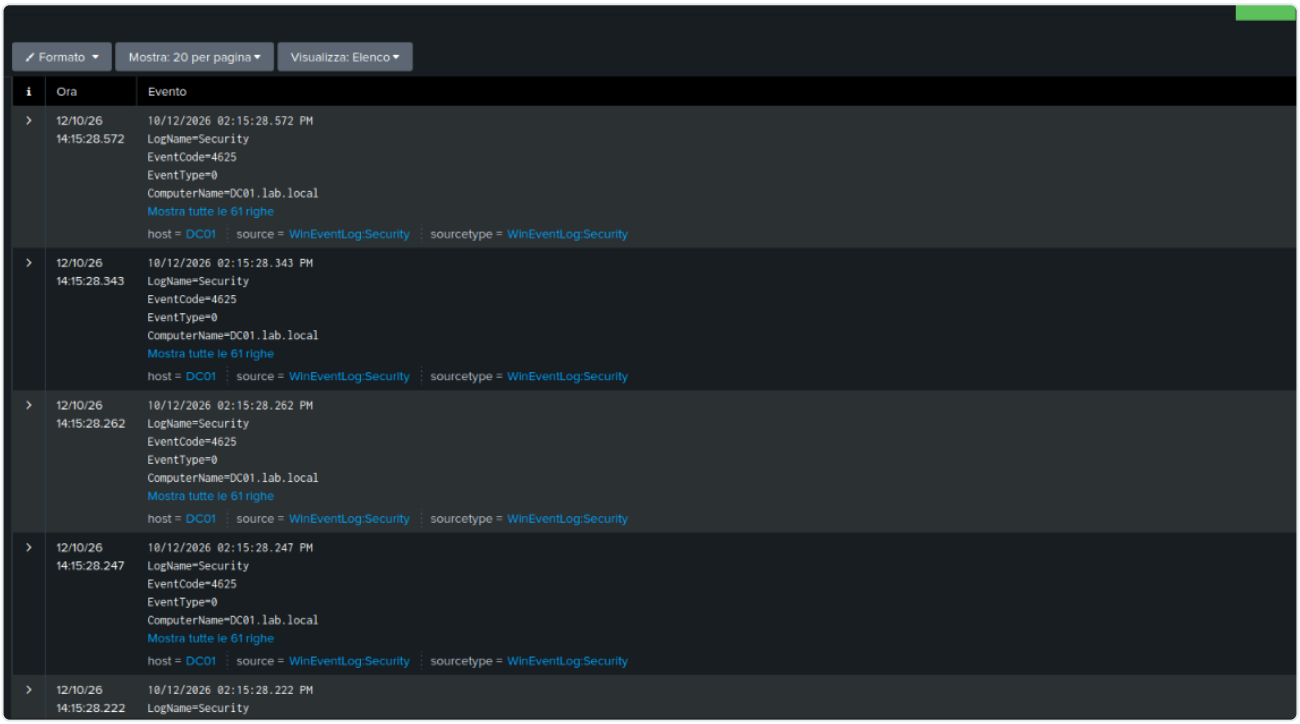


Fig. 23 Splunk: 61 eventi 4625 (logon falliti) — il password spraying rilevato.

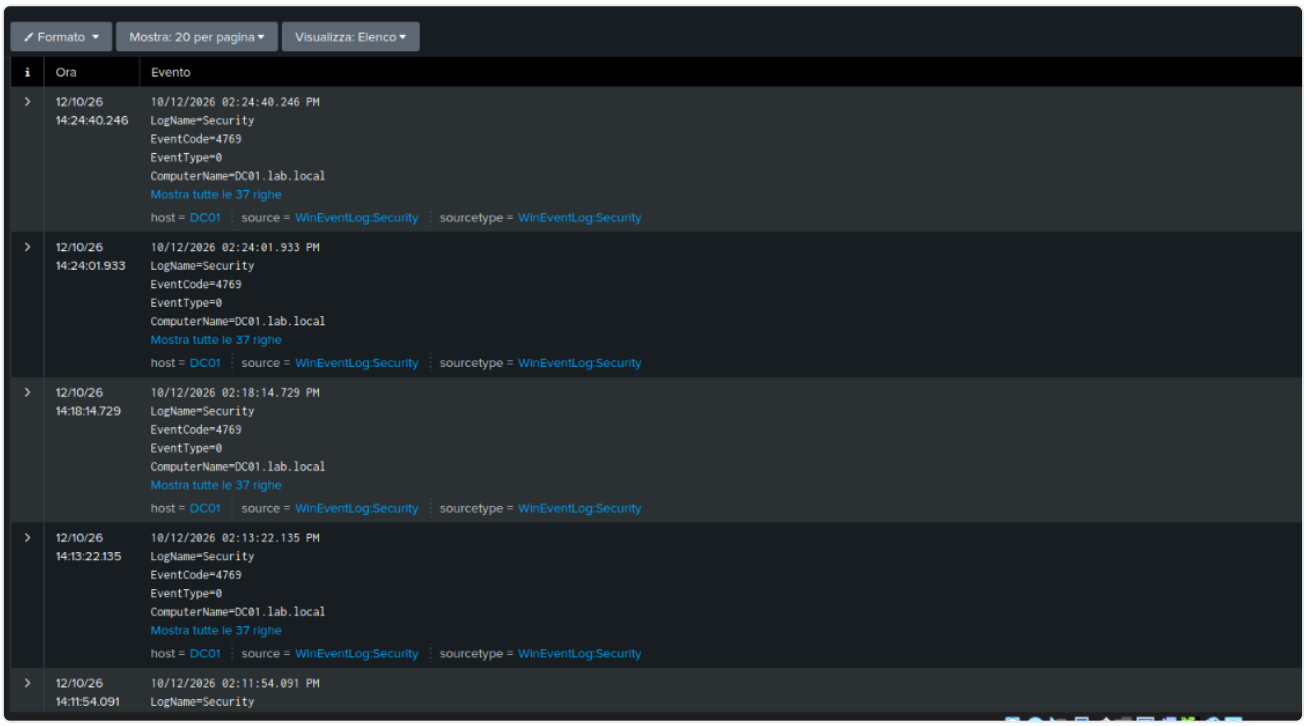


Fig. 24 Splunk: eventi 4769 — le richieste di ticket del Kerberoasting.

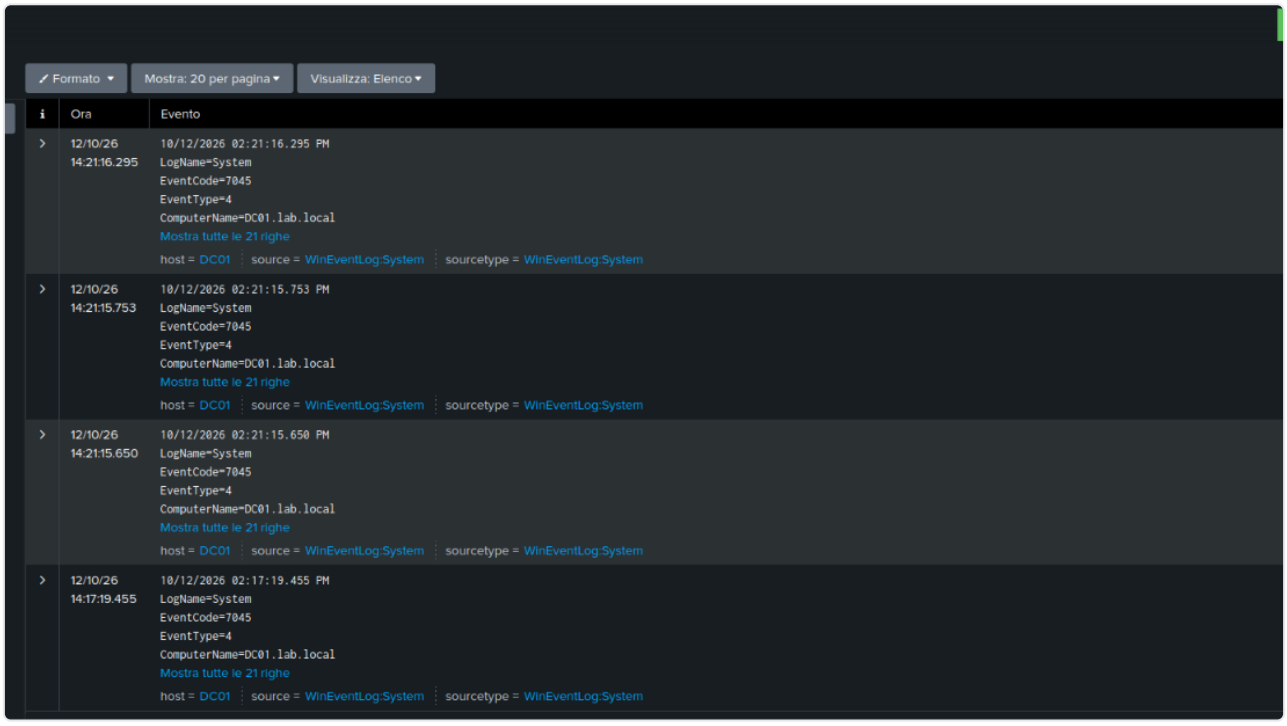


Fig. 25 Splunk: eventi 7045 — i servizi installati da PsExec sul DC.

CORRELAZIONE RIUSCITA

Gli orari degli eventi su Splunk coincidono con quelli degli attacchi lanciati dalla Kali (ad esempio il picco di 61 eventi `4625` corrisponde al password spraying, e gli eventi `7045` ai PsExec). La catena **attacco → log sul DC → Universal Forwarder → Splunk → ricerca** è pienamente funzionante.

Tabella riepilogativa attacco ↔ detection

Attacco	Strumento / comando	Esito	Event ID	Rilevato
Ricognizione / enumerazione	`nmap` · `netexec`	DC e utenti individuati	—	—
AS-REP Roasting	`GetNPUsers` + John	`abianchi : Estate2024`	`4768`	✓
Kerberoasting	`GetUserSPNs` + John	`svc_sql : Summer2024`	`4769`	✓
Password spraying	`netexec smb`	`mrossi`, `lverdi`	`4625`	✓
Movimento laterale	`impacket-psexec`	shell `nt authority\system`	`7045`	✓

10 Conclusioni

Il progetto è stato portato a termine in tutte le sue fasi: costruzione dell'ambiente Active Directory, raccolta centralizzata dei log su un SIEM e verifica della capacità di rilevamento tramite attacchi reali. Dalla Kali sono stati eseguiti attacchi per le tre categorie richieste e, per ciascuno, è stato individuato su Splunk l'evento corrispondente, con corrispondenza temporale.

Cosa il SIEM ha rilevato bene. Gli attacchi più "rumorosi" sono emersi con chiarezza: il password spraying ha prodotto un picco di 61 eventi `4625` (logon falliti), il movimento laterale PsExec ha lasciato eventi `7045` (installazione di servizi con nome casuale), e le attività Kerberos sono tracciate dagli eventi `4768` e `4769`. La catena di raccolta dei log si è dimostrata affidabile anche dopo un riavvio del SIEM, grazie alla bufferizzazione dell'Universal Forwarder.

Cosa è più difficile da rilevare. La fase di *crack offline* degli hash (AS-REP e Kerberoasting) avviene interamente sulla macchina dell'attaccante e **non genera alcun log** sul dominio: il SIEM vede solo la richiesta iniziale del ticket, non la successiva decifrazione. Questo evidenzia l'importance di rilevare l'attacco al momento della richiesta anomala (es. ticket Kerberos con cifratura RC4 debole, `0x17`), prima che la password venga compromessa.

Possibili miglioramenti / alert. Si potrebbero configurare in Splunk degli avvisi automatici: una soglia di eventi `4625` in pochi secondi (spray/brute force); un alert su `4769` con cifratura RC4 (Kerberoasting); un alert su ogni evento `7045` con nome di servizio casuale (PsExec); e un alert sugli eventi `4768` per account con pre-autenticazione disabilitata (AS-REP Roasting).